

DOCUMENTACIÓN TÉCNICA PROFESIONAL

Ataque MAC Flooding | Desbordamiento de Tabla CAM

Randy Nin | Matrícula: 2025-0660

Índice

- Contexto técnico
- Objetivos
- Alcance y uso ético
- Entorno del laboratorio
- Configuración del entorno
- Herramienta: mac_flooding.py
 - 6.1 Requisitos del entorno
 - 6.2 Parámetros de ejecución
 - 6.3 Análisis técnico del script
- Desarrollo del ataque
 - 7.1 Estado inicial de la tabla CAM
 - 7.2 Ejecución del ataque
 - 7.3 Evidencia del desbordamiento
- Pre-mitigación: limpieza de la tabla CAM
- Mitigación aplicada: Port Security
- Verificación post-mitigación
- Conclusión
- Referencias

I. Contexto técnico

Los switches Ethernet operan en Capa 2 manteniendo una tabla interna llamada CAM (Content Addressable Memory), también conocida como tabla de direcciones MAC. Esta tabla asocia cada dirección MAC con el puerto físico por el que fue aprendida, permitiendo al switch reenviar cada trama únicamente hacia el puerto donde reside el destinatario en lugar de replicarla por todos los puertos, que es el comportamiento de un hub.

El aprendizaje de la tabla CAM es completamente dinámico y sin autenticación: el switch registra la dirección MAC de origen de toda trama que recibe, independientemente de quién la haya generado. Esta ausencia de verificación introduce la vulnerabilidad conocida como MAC Flooding. Si un atacante inyecta masivamente tramas con direcciones MAC de origen completamente aleatorias, el switch las procesa e incorpora como dispositivos legítimos hasta agotar la capacidad de la tabla. Cuando esto ocurre, el switch no puede registrar nuevas entradas y ante cualquier trama cuyo destinatario no esté en la tabla responde inundando el tráfico por todos sus puertos, degradando su comportamiento al de un hub. En ese estado, todo el tráfico de la VLAN queda expuesto en cada puerto del switch, incluido el del atacante.

2. Objetivos

2.1 Objetivo del laboratorio

Demostrar en un entorno controlado de GNS3 que un atacante con acceso a un puerto del switch puede desbordarlo con entradas MAC falsificadas, haciendo escalar el Dynamic Address Count de la tabla CAM de 2 entradas legítimas a miles en cuestión de segundos, y verificar que la funcionalidad de Port Security bloquea este comportamiento de forma automática al detectar la primera violación.

2.2 Objetivo del script

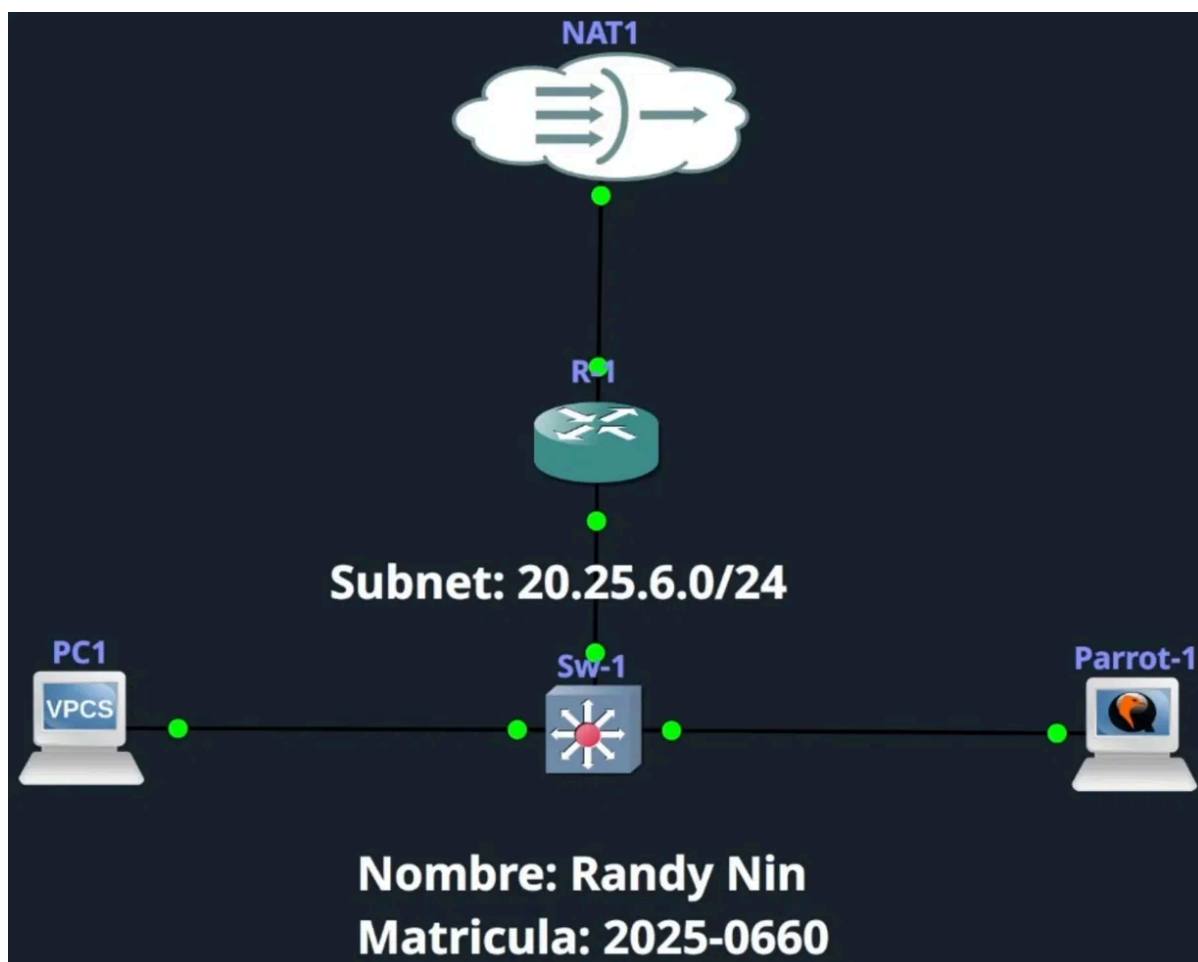
Automatizar el envío masivo y continuo de tramas Ethernet con direcciones MAC de origen completamente aleatorias hacia la dirección de broadcast, forzando al switch a registrar cada trama como un nuevo dispositivo legítimo hasta saturar el espacio disponible en su tabla CAM.

3. Alcance y uso ético

Esta práctica fue desarrollada con fines exclusivamente académicos dentro de un entorno aislado en GNS3. Las técnicas documentadas solo pueden utilizarse en redes propias o entornos de prueba autorizados como GNS3, EVE-NG o PNETLab. Su aplicación en redes de terceros, corporativas o institucionales sin autorización expresa constituye una violación legal y queda completamente fuera del alcance de este laboratorio.

4. Entorno del laboratorio

La topología consiste en un router que actúa como gateway con servidor DHCP y salida a internet mediante NAT, un switch de Capa 2 que interconecta todos los dispositivos, la máquina atacante y PCi como host legítimo. El switch Sw-1 es la víctima directa del ataque, ya que es su tabla CAM la que se busca desbordar. Ninguna configuración previa fue aplicada en el switch al inicio del laboratorio.



Red de laboratorio: 20.25.6.0/24

Dispositivo	Rol	Interfaz	IP	MAC	Modelo
R-I	Gateway / DHCP / NAT	Gio/o (LAN - inside)	20.25.6.60/24	0c:16:94:84:00:00	Cisco IOSv 15.6(2)T
R-I	Gateway / DHCP / NAT	Gio/I (WAN - outside, DHCP)	N/A	N/A	Cisco IOSv 15.6(2)T
Sw-I	Switch víctima (Capa 2)	GiI/o (uplink a R-I)	N/A	N/A	Cisco IOSvL2 15.2
PCi	Host legítimo	eo	20.25.6.61/24 (DHCP)	00:50:79:66:68:00	VPCS
Parrot-I	Atacante	ens4-Gio/o -> Sw-I	20.25.6.64/24 (DHCP)	0c:db:b8:ad:00:00	ParrotSec OS
NATi	Nube / Salida internet	N/A	N/A	N/A	N/A

Nota: La tabla CAM muestra únicamente las MACs de R-I y Parrot-I en el estado inicial porque PCi no había generado tráfico aún. El aprendizaje ocurre la primera vez que un dispositivo transmite una trama, no al conectarse físicamente.

5. Configuración del entorno

El router R-I provee el servicio DHCP para la red 20.25.6.0/24, reservando las primeras 60 IPs para infraestructura y entregando el gateway 20.25.6.60 a todos los clientes. La salida a internet se gestiona mediante NAT PAT. El switch Sw-I opera con todos sus parámetros en valores predeterminados de fábrica.

```
ip dhcp excluded-address 20.25.6.1 20.25.6.60
ip dhcp pool Pool
network 20.25.6.0 255.255.255.0
dns-server 8.8.8.8
default-router 20.25.6.60

access-list 1 permit 20.25.6.0 0.0.0.255
ip nat inside source list 1 interface GigabitEthernet0/1 overload
```

```
interface GigabitEthernet0/0
  ip address 20.25.6.60 255.255.255.0
  ip nat inside

interface GigabitEthernet0/1
  ip address dhcp
  ip nat outside
```

6. Herramienta: mac_flooding.py

6.1 Requisitos del entorno

Sistema operativo: ParrotSec OS, Kali Linux o cualquier distribución Linux con soporte para envío de paquetes raw a nivel de Capa 2.

Privilegios: El script verifica `os.geteuid()` al iniciarse y termina con un error controlado si no se ejecuta con `sudo`.

Python: Versión 3.x.

Librerías externas requeridas:

Librería	Función en el script	Instalación
scapy	Construcción de tramas Ethernet con MACs de origen aleatorias y envío a nivel Capa 2 mediante <code>sendp</code>	<code>pip install scapy</code>
termcolor	Salida coloreada en terminal para mensajes de estado, advertencias y resultados	<code>pip install termcolor</code>
pwntools	Barra de progreso en tiempo real con <code>log.progress</code> mostrando el conteo acumulado de paquetes enviados	<code>pip install pwntools</code>

Los módulos `argparse`, `random`, `sys`, `os`, `time` y `signal` son parte de la librería estándar de Python 3 y no requieren instalación adicional.

Instalación de dependencias:

```
pip install scapy termcolor pwntools
```

Conectividad requerida: El sistema atacante debe estar conectado directamente a algún puerto del switch víctima. No se requiere ninguna configuración IP activa para ejecutar el ataque; el script opera exclusivamente a nivel de Capa 2 y no depende de ninguna dirección de red.

6.2 Parámetros de ejecución

Parámetro	Flag	Requerido	Valor por defecto	Descripción
Interfaz de red	<code>-i / --interface</code>	Sí	N/A	Interfaz desde la que se envían las tramas con MACs falsificadas
Cantidad de paquetes	<code>-c / --count</code>	No	<code>0</code> (infinito)	Número máximo de tramas a enviar. El valor <code>0</code> activa el modo infinito sin límite de paquetes
Delay entre paquetes	<code>-d / --delay</code>	No	<code>0.001</code>	Tiempo en segundos entre cada trama enviada. El valor <code>0.0</code> elimina cualquier pausa para máxima velocidad

Sintaxis:

```
sudo python3 mac_flooding.py -i <interfaz> -c <cantidad> -d <delay>
```

Comando utilizado en el laboratorio:

```
sudo python3 mac_flooding.py -i ens4 -c 80000000 -d 0.00
```

Este comando configura el ataque para enviar hasta 80 millones de tramas sin ningún delay entre ellas, maximizando la tasa de inyección para llenar la tabla CAM en el menor tiempo posible. La ejecución termina al alcanzar el límite configurado o al presionar `Ctrl+C`, lo que activa el handler `SIGINT` y finaliza el proceso de forma limpia.

6.3 Análisis técnico del script

El script genera cada trama Ethernet desde cero en cada iteración del loop principal. La dirección MAC de origen se construye de forma completamente aleatoria usando `random.randint(0, 255)` para cada uno de los seis octetos, con el prefijo `02` fijado en el primer octeto para activar el bit de administración local y garantizar que el rango no colisione con MACs de fabricante registradas.

Formato de la MAC generada:

```
02:XX:XX:XX:XX:XX
  └─ 5 octetos con valor 0-255 aleatorio e independiente por octeto
```

Estructura de la trama enviada en cada iteración:

```
Ethernet
├─ src : MAC aleatoria (02:xx:xx:xx:xx:xx)
├─ dst : ff:ff:ff:ff:ff:ff (broadcast)
└─ Payload:
    └─ IP(src="1.2.3.4", dst="5.6.7.8")
        └─ ICMP()
```

El destino broadcast garantiza que el switch procese la trama y la propague por todos los puertos, registrando la MAC de origen falsa como si fuera un dispositivo legítimo recién descubierto. La carga IP/ICMP es un payload de relleno sin relevancia funcional para el ataque; el vector real es exclusivamente la MAC de origen aleatoria que el switch incorpora a su tabla CAM con cada trama recibida.

El indicador de `pwntools` actualiza el conteo de paquetes en pantalla cada 100 tramas enviadas, mostrando en tiempo real el avance del desbordamiento.

7. Desarrollo del ataque

7.1 Estado inicial de la tabla CAM

Antes del ataque, la tabla CAM de Sw-I contiene únicamente dos entradas dinámicas: la MAC del router R-I aprendida por Gi1/0 y la MAC de Parrot-I aprendida por Gi0/0. El espacio disponible en la tabla es de aproximadamente 70 millones de entradas, lo que ilustra tanto la escala del hardware como la viabilidad práctica del ataque si se le da tiempo suficiente.

Switch#show mac address-table			
Mac Address Table			
Vlan	Mac Address	Type	Ports
1	0c16.9484.0000	DYNAMIC	Gi1/0
1	0cdb.b8ad.0000	DYNAMIC	Gi0/0

Total Mac Addresses for this criterion: 2

Switch#

Switch#show mac address-table count	
Mac Entries for Vlan 1:	
Dynamic Address Count	: 2
Static Address Count	: 0
Total Mac Addresses	: 2

Total Mac Address Space Available: 70152664

Switch#

7.2 Ejecución del ataque

El script se lanza desde la terminal de Parrot-I con privilegios de root, sin delay entre paquetes y con un límite de 80 millones de tramas para garantizar suficiente tiempo de demostración sin requerir intervención manual.

```
> python3 exploit.py -i ens4 -c 80000000 -d 0.00
[*] Starting MAC Flooding attack on ens4
[!] This will overflow the switch CAM table
[!] When successful, the switch will act as a hub
[*] Delay between packets: 0.0s
[*] Mode: Limited to 80000000 packets

[b] MAC Flooding: 400 packets with unique MACs sent
```

7.3 Evidencia del desbordamiento

Con el script activo, la tabla CAM crece de forma acelerada. Cada trama procesada añade una nueva entrada con una MAC de origen distinta, y en cuestión de segundos el conteo escala a miles de entradas dinámicas. Si el ataque se mantuviera durante el tiempo necesario, la tabla alcanzaría su límite máximo de ~70 millones de entradas y el switch comenzaría a actuar como

hub, inundando todo el tráfico de la VLAN por todos sus puertos y exponiendo las comunicaciones de cualquier dispositivo conectado al atacante.

```
Switch#show mac address-table count

Mac Entries for Vlan 1:
-----
Dynamic Address Count   : 2987
Static Address Count    : 0
Total Mac Addresses     : 2987

Total Mac Address Space Available: 70152664
```

8. Pre-mitigación: limpieza de la tabla CAM

Antes de configurar la contramedida, se eliminaron todas las entradas dinámicas acumuladas durante el ataque para devolver el switch a su estado base y demostrar el efecto de la mitigación desde un punto de partida limpio.

```
Switch#clear mac address-table dynamic
```

```
Switch#show mac address-table count

Mac Entries for Vlan 1:
-----
Dynamic Address Count   : 2
Static Address Count    : 0
Total Mac Addresses     : 2

Total Mac Address Space Available: 70152664
```

9. Mitigación aplicada: Port Security

La contramedida implementada es Port Security, configurada sobre el puerto Gio/o de Sw-1, que es el puerto de acceso donde Parrot-1 está conectado. Esta funcionalidad permite al switch restringir cuántas y cuáles direcciones MAC pueden ser aprendidas por un puerto físico dado, y define la acción automática ante cualquier violación detectada.

Por razones de alcance del laboratorio, la configuración se aplicó exclusivamente en el puerto del atacante. En un entorno de producción, la práctica recomendada es aplicar Port Security en todos los puertos de acceso y en todos los puertos no utilizados del switch.

```

Switch# conf t
Switch(config)# interface GigabitEthernet0/0
Switch(config-if)# switchport mode access
Switch(config-if)# switchport port-security
Switch(config-if)# switchport port-security maximum 1
Switch(config-if)# switchport port-security mac-address sticky
Switch(config-if)# switchport port-security violation shutdown
Switch(config-if)# exit

```

Comando	Función
<code>switchport mode access</code>	Configura el puerto en modo acceso, requisito previo para habilitar Port Security en IOS
<code>switchport port-security</code>	Activa Port Security en la interfaz
<code>switchport port-security maximum 1</code>	Limita a una sola dirección MAC activa por puerto en cualquier momento
<code>switchport port-security mac-address sticky</code>	Activa el aprendizaje automático: la primera MAC que aparezca queda registrada de forma permanente como entrada segura
<code>switchport port-security violation shutdown</code>	Ante cualquier MAC adicional que no coincida con la registrada, el switch pone el puerto en estado err-disable y lo apaga automáticamente

```

Switch#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#int gig0/0
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 1
Switch(config-if)#switchport port-security mac-address sticky
Switch(config-if)#switchport port-security violation shutdown
Switch(config-if)#exit
Switch(config)#

```

10. Verificación post-mitigación

Con Port Security activo en Gio/o, se ejecutó nuevamente el script con los mismos parámetros. Al iniciarse el ataque, el switch aprende la primera MAC generada aleatoriamente por el script y la registra como entrada sticky. La siguiente trama con una MAC de origen diferente representa una violación directa de la política configurada: el switch la detecta, registra el evento en el log del sistema y coloca el puerto Gio/o en estado err-disable, apagándolo de forma automática e inmediata.

El script solo alcanzó a enviar 200 paquetes antes de que el switch desactivara el puerto, bloqueando por completo el canal del atacante.

```
> python3 exploit.py -i ens4 -c 80000000 -d 0.00
[*] Starting MAC Flooding attack on ens4
[!] This will overflow the switch CAM table
[!] When successful, the switch will act as a hub
[*] Delay between packets: 0.0s
[*] Mode: Limited to 80000000 packets

[>] MAC Flooding: 200 packets with unique MACs sent
```

```
Switch#
*Jun  3 09:45:51.562: %SYS-5-CONFIG_I: Configured from console by console
*Jun  3 09:46:00.756: %PM-4-ERR_DISABLE: psecure-violation error detected on Gi0/0, putting Gi0/0 in err-disable state
*Jun  3 09:46:00.757: %PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused by MAC address 0208.f3d9.219e on port GigabitEthernet0/0.
*Jun  3 09:46:01.757: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to down
*Jun  3 09:46:02.757: %LINK-3-UPDOWN: Interface GigabitEthernet0/0, changed state to down
```

Comandos de verificación adicionales:

```
Sw-1# show port-security interface GigabitEthernet0/0
Sw-1# show port-security address
Sw-1# show interfaces GigabitEthernet0/0 status
```

Nota de recuperación: Para rehabilitar el puerto después de una violación con acción shutdown, es necesario ejecutar manualmente shutdown seguido de no shutdown en la interfaz, o configurar errdisable recovery cause psecure-violation con un tiempo de recuperación automático para entornos de producción donde la intervención manual no es siempre viable.

II. Conclusión

El laboratorio confirma que la tabla CAM de los switches Cisco, al registrar dinámicamente cualquier MAC de origen sin ningún tipo de verificación ni control de frecuencia, es inherentemente vulnerable al desbordamiento desde cualquier puerto de acceso. El escalamiento de 2 a 2987 entradas en segundos evidencia la efectividad del flooding y su capacidad para degradar el comportamiento del switch hacia el de un hub si se sostiene durante el tiempo suficiente para llenar las ~70 millones de entradas disponibles.

Port Security neutraliza el ataque al nivel del puerto físico sin requerir ningún cambio en los dispositivos finales. Su configuración con sticky learning y acción de shutdown garantiza que el primer intento de flooding resulte en la desactivación inmediata del puerto del atacante, eliminando el vector de ataque de raíz y dejando un registro en el log del sistema que facilita la detección forense del incidente.

12. Referencias

- Repositorio del script: <https://github.com/RandyNin/MAC-FLOODING>
- Video demostrativo: https://www.youtube.com/watch?v=eIKalNX6-uY&list=PLxMefEiS_P6q8NowKhpkK-Jj_UTiBmuzp
- Plataforma: GNS3 / Entorno controlado de Seguridad de Redes

Randy Nin / Matrícula 2025-0660